



ACTIVIDAD 01- ANÁLISIS Y PLANIFICACIÓN DEL PESTEST

NOMBRE: ERIKA GABRIELA QUISHPI CONTENTO

HACKER WOMEN COUNCIL -ETHICAL HACKING

Escenario: Aurora Market

1. OBJETIVO DEL PENTEST

- Determinar la postura de seguridad de la aplicación web de Aurora Market mediante la identificación y verificación de vulnerabilidades.
- Identificar qué información de la infraestructura y bases de datos puede ser expuesta o descubierta por un atacante externo.
- Proporcionar recomendaciones técnicas precisas para corregir los hallazgos y respaldar la toma de decisiones estratégicas.

2. ALCANCE

Se evaluará:

- Aplicación web principal de Aurora Market
- Mecanismos de autenticación, control de acceso y manejo de sesiones.
- Base de datos y APIs expuestas vinculadas a la aplicación web.
- Descubrimiento activo de tecnologías y rutas no documentadas en el entorno web.

No se evaluará:

- Ataques de Denegación de Servicio (DoS / DDoS) que degraden la disponibilidad del servicio.
- Ingeniería social, phishing o ataques directos a empleados y clientes.
- Equipos personales o infraestructura ajena al entorno web de Aurora Market.

3. AUTORIZACIÓN Y CONDICIONES

Aurora Market proporciona autorización formal.

CONDICIONES

- La evaluación deberá realizarse únicamente sobre la aplicación web autorizada.
- No se permite atacar las redes sociales de la empresa, los equipos personales de sus empleados, sus cuentas de correo, proveedores externos ni otros sistemas que no formen parte del alcance acordado.
- No está permitido realizar acciones que puedan interrumpir deliberadamente el funcionamiento de la plataforma o afectar información de los clientes.



ACTIVIDAD 01- ANÁLISIS Y PLANIFICACIÓN DEL PESTEST

NOMBRE: ERIKA GABRIELA QUISHPI CONTENTO

HACKER WOMEN COUNCIL -ETHICAL HACKING

- Las pruebas deben realizarse durante horarios de menor actividad para reducir cualquier posible impacto sobre las operaciones.
- Confianza, transparencia y comunicación.

4. TIPO DE PENTEST

Black Box (Caja Negra): Al no tener conocimiento previo de la infraestructura, código o configuraciones, permitirá tener un escenario real de como está viendo un atacante real la aplicación web de Aurora Market.

5. PLANIFICACIÓN

- **Objetivo:** Evaluar la postura de seguridad de Aurora Market e identificar riesgos técnicos mayores.
- **Alcance:** Aplicación web, mecanismos de autenticación y base de datos asociada.
- **Permisos y condiciones:** No ataques destructivos, no DDoS, documentación detallada de hallazgos y ejecución en horarios autorizados.
- **Metodología a utilizar:** OWASP Top 10 y Penetration Testing Execution Standard (PTES).
- **Recopilación de información previa:** existencia de la aplicación web
- **Recursos necesarios:** Herramientas de interceptación de tráfico (Burp Suite, OWASP ZAP), escaneadores de red/puertos (Nmap) y navegadores web.
- **Programación del pentest:** Definir periodo de fechas.

6. FASES DEL PENTEST

- 1. Reconocimiento:** Recopilación de información pública, fingerprinting de tecnologías (servidor web, lenguaje, frameworks) y mapeo de rutas.
- 2. Análisis de vulnerabilidades:** Identificación de fallos de configuración, puertos abiertos, componentes desactualizados o debilidades lógicas.
- 3. Explotación:** Verificación manual de vulnerabilidades (inyecciones SQL, XSS, bypass de autenticación) sin alterar la disponibilidad ni los datos.
- 4. Post-explotación:** Evaluación del nivel de acceso alcanzado y determinación del impacto real sobre el negocio.



ACTIVIDAD 01- ANÁLISIS Y PLANIFICACIÓN DEL PESTEST

NOMBRE: ERIKA GABRIELA QUISHPI CONTENTO

HACKER WOMEN COUNCIL -ETHICAL HACKING

5. Informe: Elaboración del informe técnico detallado para desarrollo y del informe claro para la toma de decisiones.

7. INVESTIGACIÓN

OWASP Testing Guide (Web Security Testing Guide - WSTG)

Enfoque específico en aplicaciones web: Aurora Market es una tienda online con autenticación, manejo de usuarios y base de datos. La guía WSTG de OWASP ofrece un marco exhaustivo diseñado específicamente para evaluar capas web, permitiendo probar controles de acceso, gestión de sesiones, validación de entradas y lógica de negocio.

Descubrimiento técnico en escenarios de información limitada: Dado que partimos de un escenario de **Caja Negra** donde no se conoce la infraestructura interna, WSTG proporciona pasos estructurados de reconocimiento e identificación de tecnologías (*fingerprinting*) para descubrir componentes, APIs o rutas no documentadas sin comprometer la disponibilidad del servicio.

Estandarización y mitigación clara: Permite clasificar las vulnerabilidades encontradas bajo un estándar reconocido mundialmente, facilitando al equipo de desarrollo de Aurora Market la comprensión de los riesgos técnicos y la aplicación de remediaciones precisas.